



Nmap: Escaneo de Puertos

La anatomía del descubrimiento de
redes y análisis de servicios.

Presentado por Carlos Noboa

Terminal

[STATUS: READY] // INITIATING SCANS... █

El Objetivo del Escaneo

El escaneo de puertos permite identificar los servicios expuestos por un activo, aumentando la superficie de exposición a ataques e identificando potenciales vulnerabilidades

Perfilado Tecnológico

Un servidor aparentemente bastionado puede tener servicios ocultos que comprometan su seguridad.

Error Humano

Pese a tener alta ciberseguridad, muchas brechas provienen de exponer información confidencial por error.

90% / 10%

En un escenario real, un atacante emplea el 90% de su tiempo elaborando un perfil del objetivo y solo un 10% ejecutando el ataque.

SSH
[PORT 22]

HTTP
[PORT 80]

DATABASE
[PORT 3306]

DATABASE
[PORT 3306]

REMOTE
DESKTOP
[PORT 3389]

FTP
[PORT 21]

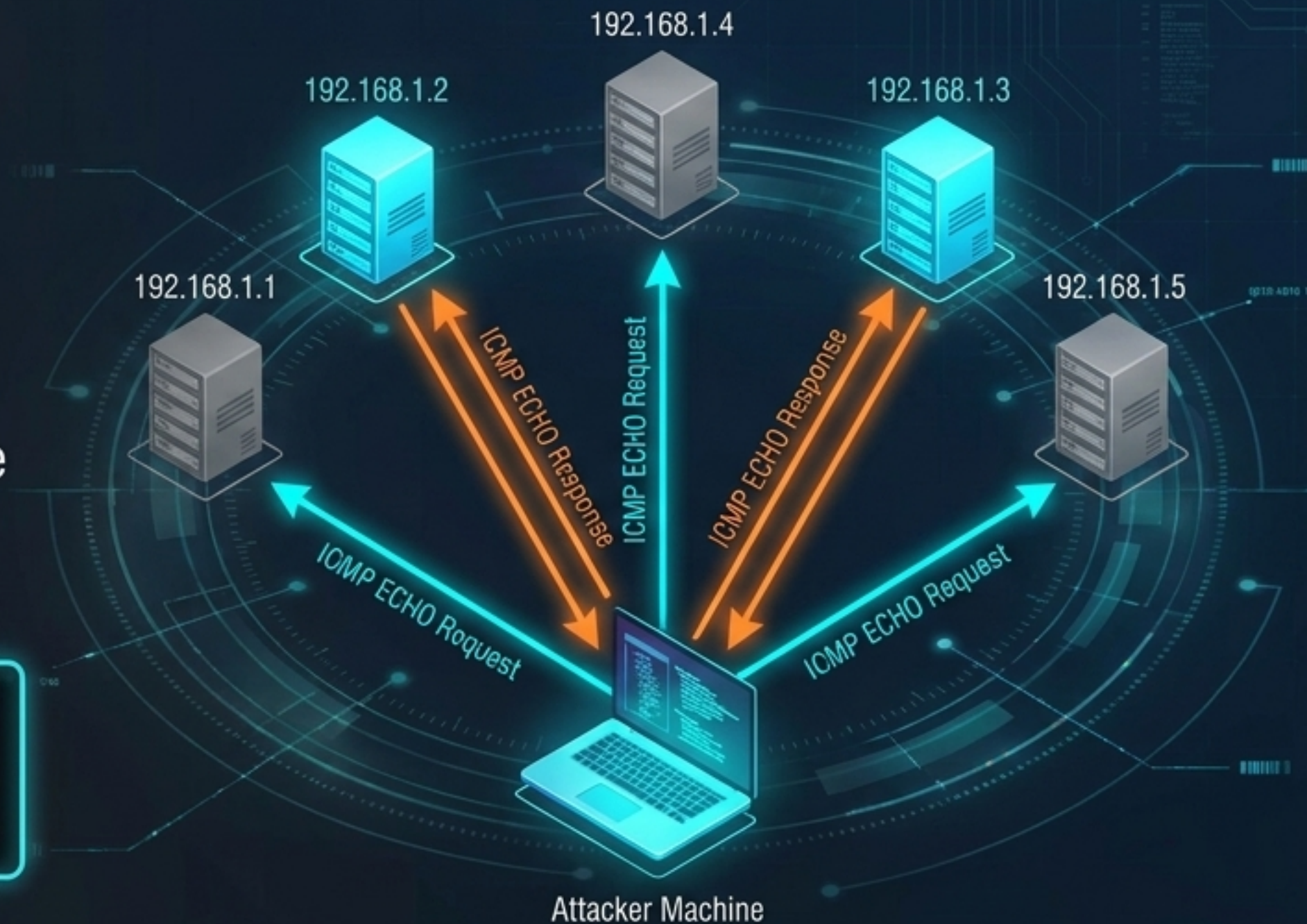
UNKNOWN
SERVICE
[PORT 5000]

Descubrimiento Base: Ping Sweep

Antes de escanear puertos, determinamos qué direcciones IP de un rango están activas enviando paquetes a toda la red.

- Utiliza el Protocolo de mensajes de control de Internet (ICMP) (RFC 792), diseñado para proporcionar informes de estado y errores en la red.

```
nmap -sn <hosts>
```



El Mapa de Puertos (Servicios TCP/UDP)

Web



80
http

443
https

8080
http-proxy

Acceso Remoto



22
ssh

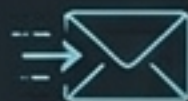
23
telnet

3389
rdp

5900
vnc

1723
pptp

Correo y Transferencia



21
ftp

25
smtp

110
pop3
995
pop3s

143
imap
993
imaps

Infraestructura y Bases de Datos



53
dns

111
rpcbind

135
msrpc
139
netbios
445
microsoft-ds

3306
mysql

Interpretando las Respuestas: Los 4 Estados



Abierto (Open)

La aplicación en la máquina destino está activamente esperando conexiones o paquetes en este puerto.



Filtrado (Filtered)

Un firewall, filtro u obstáculo en la red bloquea el acceso. Nmap no puede determinar si está abierto o cerrado.



Cerrado (Closed)

El puerto es accesible (responde a Nmap), pero no hay ninguna aplicación escuchando en él.



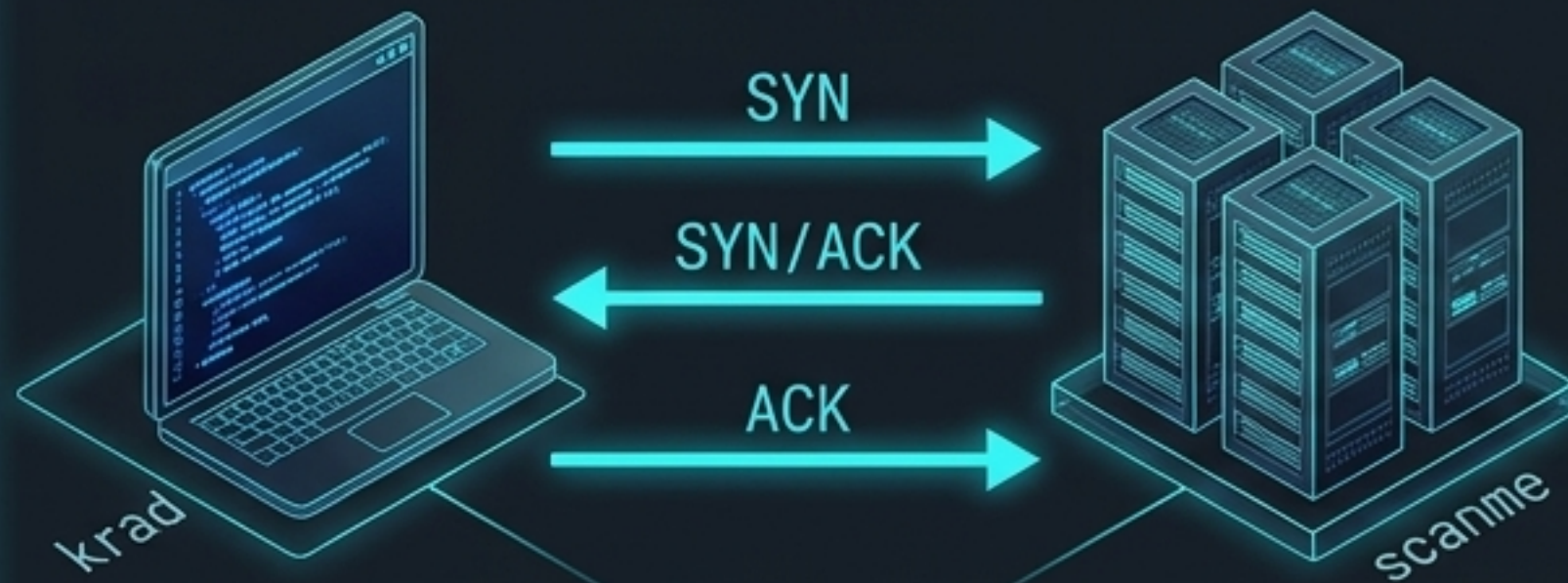
No Filtrado (Unfiltered)

El puerto responde al escaneo, pero Nmap no tiene suficiente información para determinar si se encuentra abierto o cerrado.

Maniobras Tácticas: TCP vs. SYN Scan

Nmap soporta doce tipos de escaneo, permitiendo adaptar la táctica al entorno.

TCP Scan (-sT)



- Realiza el proceso completo de conexión (3-way handshake).
- Identificación altamente fiable.
- **Desventaja:** Es un escaneo ruidoso y lento. Deja registros en los logs del servidor.

SYN Scan (-sS)



- La variante sigilosa (TCP half-open).
- Nmap envía SYN. Si recibe SYN/ACK (puerto abierto), envía un paquete RST para cancelar la conexión antes de que se complete.
- **Ventaja:** Mayor rapidez. Sin embargo, muchos firewalls modernos ya filtran esta técnica.

El Desafío del UDP Scan (-sU)

Ignorar el escáner UDP es un error crítico, ya que servicios vitales de infraestructura operan exclusivamente bajo este protocolo.

Mecanismo

Nmap lanza una petición REQUEST al puerto y espera. Al ser un protocolo no orientado a conexión, si no hay respuesta, no se tiene certeza de si el puerto está cerrado o filtrado.

Lentitud y Timeouts

Son escaneos extremadamente lentos, obligando al escáner a esperar el 'timeout' del servidor para evaluar el estado del puerto.

Objetivos UDP Clave

DHCP (67/68)
SNMP (161, 162)
DNS (53)
Xbox Live (88)



Evación y Escaneos Especializados

Escaneo TCP ACK



Objetivo:

No busca puertos abiertos, sino mapear las reglas del firewall.

Mecanismo:

Envía paquetes con el flag ACK para determinar si el cortafuegos es stateful (mantiene estado) o stateless.

Escaneo TCP X-MAS



Objetivo:

Explotar la respuesta de sistemas antiguos.

Mecanismo:

Ilumina el paquete como un "árbol de navidad" activando los flags FIN, URG y PSH. Antiguamente, TCP/IP respondía con RST+ACK si estaba cerrado.

Escaneo TCP NULL



Objetivo:

Detectar anomalías enviando el vacío.

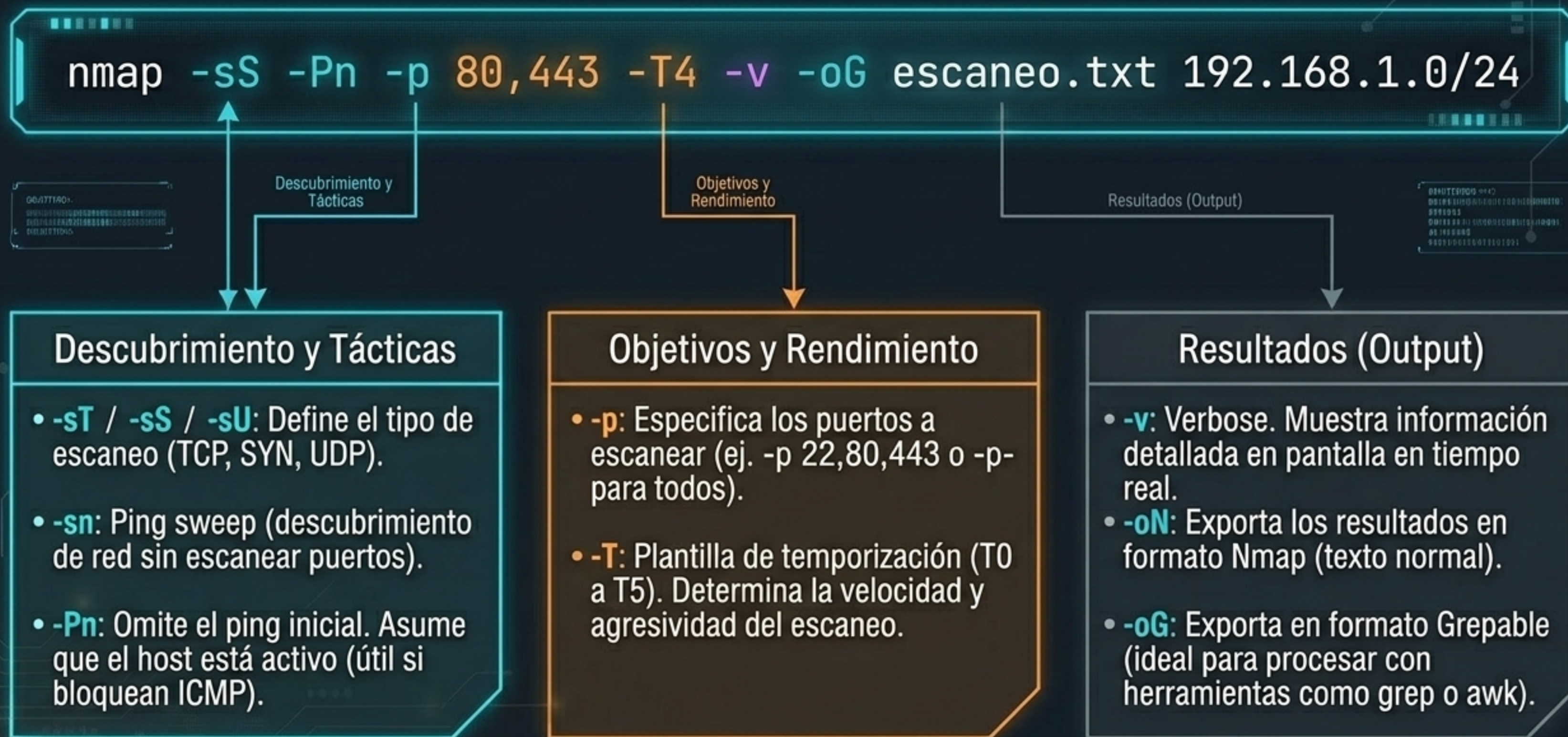
Mecanismo:

Envía un paquete que no contiene ningún bit encendido. Si está abierto, no hay respuesta; si está cerrado, responde con RST+ACK.

Matriz de Resolución de Escaneos

Tipo	Parámetro	Protocolo	Velocidad	Sigilo	Caso de Uso Principal
TCP Full	`-sT`	TCP	Lento	Bajo	Verificación exhaustiva, sin permisos de root.
SYN Half	`-sS`	TCP	Rápido	Medio	Escaneo estándar, evasión básica de logs.
UDP Scan	`-sU`	UDP	Muy Lento	Medio	Descubrir servicios de infraestructura (DNS, SNMP).
ACK Scan	`N/A`	TCP	Rápido	Alto	Mapeo y evasión de reglas de Firewall.
X-MAS/NULL	`N/A`	TCP	Variable	Alto	Evasión avanzada y escaneo de sistemas heredados.

Construyendo el Comando: Panel de Parámetros



Del Perfilado a la Auditoría

El **escaneo de puertos** es la base de cualquier auditoría de seguridad. El dominio de **Nmap** y sus parámetros transforma el caos de una red desconocida en un **mapa táctico claro**, marcando la frontera exacta entre la **recolección de información** y el inicio del movimiento lateral o la explotación.



[SCAN COMPLETE] // TOPOLOGY MAPPED // READY FOR EXPLOIT PHASE.